

Informe de gestión de incidentes conforme a la norma ISO 27001:

vulnerabilidad de inyección SQL en un entorno de laboratorio controlado

Introducción

Este informe documenta la identificación, análisis y tratamiento de un incidente de inyección SQL realizado de forma controlada sobre la aplicación Damn Vulnerable Web Application (DVWA), desplegada en un servidor LAMP (Debian, Apache, MariaDB/MySQL y PHP) en un entorno de laboratorio aislado. El objetivo del ejercicio fue evaluar la exposición típica de una aplicación vulnerable a inyección SQL y alinear el procedimiento de gestión del incidente con los requisitos del Anexo A.16 de ISO 27001 en cuanto a registro, análisis de causa raíz, tratamiento y lecciones aprendidas.

Contexto y alcance

Activo afectado: Máquina virtual Debian con stack LAMP y DVWA instalada, configurada intencionadamente con nivel de seguridad bajo para fines educativos.

Tipo de incidente: Inyección SQL clásica (SQLi) mediante manipulación de parámetro en una consulta que no valida ni parametriza la entrada de usuario.

Alcance: Solo entorno de laboratorio, sin datos reales y sin exposición a Internet, lo que limita el impacto real a la demostración técnica y a la mejora de controles de desarrollo seguro.

Descripción del Incidente

Durante la actividad de pruebas de seguridad sobre DVWA se ejecutó un ataque de inyección SQL en el módulo "SQL Injection", accesible desde la interfaz de la aplicación. Dicho módulo construye una consulta SQL usando directamente el valor introducido en el campo "User ID", sin validación adecuada ni uso de consultas parametrizadas, lo que permite alterar la lógica de la consulta original.

En condiciones normales, al introducir un valor como 1, la aplicación genera una consulta de tipo:

```
SELECT first_name, surname FROM users WHERE user_id = '1';
```

devolviendo únicamente el registro asociado a ese identificador. Sin embargo, debido a la ausencia de controles de seguridad, la manipulación de este parámetro permite forzar la devolución de múltiples registros o eludir las condiciones de filtrado, comprometiendo la confidencialidad e integridad de la base de datos.

Proceso de Reproducción

Entrada utilizada

En el campo "User ID" del módulo "SQL Injection" se introdujo la siguiente carga sencilla:

1' OR '1'=1

Esta cadena cierra el literal del parámetro 1, introduce una condición OR siempre verdadera y mantiene la sintaxis SQL válida. La consulta resultante adopta, de forma aproximada, la siguiente forma:

```
SELECT first_name, surname FROM users WHERE user_id = '1' OR '1'=1';
```

Al evaluarse la condición OR '1'=1', que es siempre verdadera, la base de datos devuelve todos los registros que cumplen la consulta, no solo el usuario con user_id = 1. Esto demuestra que:

- La entrada del usuario se concatena directamente en la consulta SQL.
- No se aplican consultas parametrizadas ni validación de tipo/longitud sobre el campo "User ID".

Clasificación según ISO 27001 (Anexo A.16)

De acuerdo con las directrices de gestión de incidentes de ISO 27001, el evento se clasifica como:

- Tipo: Incidente de seguridad de la información (vulnerabilidad explotada con éxito).
- Categoría: Compromiso de la aplicación web por inyección SQL.
- Impacto potencial: Pérdida de confidencialidad y posible alteración de datos en la base.

Impacto del Incidente

Aunque el escenario se desarrolla en un entorno de laboratorio, si esta vulnerabilidad se encontrara en un sistema de producción podría generar los siguientes impactos:

- Acceso no autorizado a datos:
 - Lectura de información sensible de usuarios como nombres, credenciales u otros campos almacenados en tablas de usuarios o relacionadas.
 - Posible enumeración de todos los registros de una tabla mediante condiciones siempre verdaderas como OR '1'=1'.
- Modificación o borrado de datos:
 - En escenarios más avanzados, la inyección podría extenderse a operaciones de actualización o borrado (UPDATE, DELETE), afectando directamente a la integridad de la información.
- Disponibilidad y continuidad del servicio:
 - La ejecución de cargas más complejas podría derivar en bloqueo de tablas, consumo excesivo de recursos o caída del servicio, impactando en la disponibilidad de la aplicación.

En términos de ISO 27001, se ven potencialmente comprometidos los principios de confidencialidad, integridad y disponibilidad de la información, lo que requiere registro formal del incidente, evaluación de impacto y tratamiento.

Causa raíz y factores contribuyentes

El análisis de causa raíz indica que la vulnerabilidad se debe principalmente a:

- Construcción de consultas SQL mediante concatenación directa de cadenas con datos introducidos por el usuario.
- Ausencia de mecanismos de defensa como consultas parametrizadas, ORM seguro o procedimientos almacenados correctamente diseñados.
- Falta de validación de entrada (tipo de dato numérico, longitud, formato) sobre el campo "User ID".

Factores contribuyentes adicionales, extrapolables a un entorno real, incluyen:

- Políticas insuficientes de desarrollo seguro y revisión de código.
- Carencia de pruebas de seguridad sistemáticas antes de pasar a producción.
- Falta de concienciación del equipo de desarrollo sobre patrones de mitigación de SQLi.

Gestión del incidente (ciclo ISO 27001)

Conforme al Anexo A.16 de la ISO 27001, el incidente se gestiona siguiendo las etapas de identificación, registro, evaluación, respuesta y cierre.

1. Identificación y registro

- El incidente fue identificado durante una prueba de seguridad planificada sobre DVWA como parte de actividades de formación en ciberseguridad.
- Se registran fecha, entorno afectado, usuario que ejecutó la prueba, descripción técnica de la carga ('1' OR '1'='1') y resultados observados.

2. Evaluación y clasificación

- Se evalúa el impacto potencial en caso de ataque en producción, clasificando el incidente como alta criticidad por implicar acceso no autorizado a datos.
- Se determina que la causa raíz reside en malas prácticas de construcción de consultas y ausencia de validación.

3. Respuesta y contención

- En el laboratorio, la respuesta consiste en documentar el comportamiento de la aplicación y confirmar que la vulnerabilidad es reproducible.
- En un entorno real, se deberían aplicar medidas de contención como deshabilitar temporalmente la funcionalidad afectada o aplicar reglas WAF específicas para bloquear patrones de inyección.

4. Erradicación y corrección

- Definición de cambios de código para eliminar la concatenación de parámetros e introducir consultas parametrizadas.
- Revisión del modelo de validación de entradas para restringir el campo "User ID" a valores numéricos y rangos válidos.

5. Cierre y lecciones aprendidas

- Se documentan el incidente, las soluciones aplicadas y las recomendaciones de mejora para futuros desarrollos.
- Se proponen acciones de formación y actualización de políticas de desarrollo seguro para reducir la probabilidad de reaparición.

Recomendaciones

A partir del incidente, se recomiendan las siguientes acciones alineadas con las buenas prácticas de mitigación de SQLi y con los controles del Anexo A de la ISO 27001.

Controles técnicos

- Uso de consultas parametrizadas / prepared statements
Implementar acceso a base de datos mediante sentencias preparadas, asegurando que el valor del parámetro "User ID" se trate como dato y no como parte del código SQL.
- Validación estricta de entrada
Aplicar comprobaciones de tipo, longitud y formato sobre todos los campos que interactúan con la base de datos, restringiendo "User ID" a valores numéricos válidos.
Implementar listas blancas donde sea posible, rechazando caracteres no esperados como comillas u operadores lógicos en campos numéricos.
- Mínimo privilegio en la base de datos
Configurar cuentas de aplicación con privilegios reducidos, evitando otorgar permisos de administración que puedan amplificar el impacto de una inyección.
- Controles adicionales de protección
Considerar el despliegue de un WAF (Web Application Firewall) con reglas específicas para detectar y bloquear patrones de inyección SQL.

Controles organizativos y de proceso

- Política de desarrollo seguro
Incluir requisitos de prevención de inyección SQL en la política y guías de desarrollo seguro, con revisiones de código enfocadas en la gestión de entradas y acceso a la base de datos.
- Pruebas de seguridad regulares
Programar pruebas de penetración periódicas y análisis de vulnerabilidades automatizados sobre aplicaciones web para detectar SQLi y otros fallos críticos antes de la puesta en producción.
- Formación y concienciación

Formar al personal técnico en patrones seguros de acceso a bases de datos (prepared statements, ORM, validación de entradas) y concienciar al personal no técnico sobre el impacto de vulnerabilidades de este tipo.

Conclusión

El incidente controlado de inyección SQL sobre DVWA ha demostrado que una carga simple como `1' OR '1'='1` es suficiente para comprometer la lógica de una consulta cuando no se aplican controles de seguridad básicos. En un entorno de producción, una vulnerabilidad de este tipo podría conducir a la exposición y manipulación de datos críticos, afectando la confidencialidad, integridad y disponibilidad, por lo que debe tratarse como incidente de alta prioridad dentro del sistema de gestión de seguridad de la información basado en ISO 27001.

La incorporación DE consultas parametrizadas, validación robusta de entradas, privilegios mínimos y procesos formales de gestión de incidentes refuerza de forma significativa la postura de seguridad y reduce la probabilidad de explotación de inyecciones SQL en aplicaciones futuras.